

Week 3 Advanced Security and Final Reporting

Name: Syeda Arooj Fatima

ID: DHC-1161

Internship Date: 26 May 2026

Implementing Advance Security and Final Reporting on OWASP Juice Shop

Overview

In Week 3, I focused on implementing advanced security measures, performing penetration testing, and setting up logging for the OWASP Juice Shop application.

1. Basic Penetration Testing

Tools Used: Nmap

Commands Executed:

```
nmap -sV -O localhost -p 3000
nmap -A localhost
```

Key Findings:

- Port 3000 running Node.js Express server
- Service versions detected
- HTTP methods enabled

Screenshots:

```
nmap -p 3000 --script http-enum,http-headers,http-methods localhost
```

Services	Nmap Output	Ports / Hosts	Topology	Host Details	Scans
host (127.0.0.1)	<pre>nmap -p 3000 --script http-enum,http-headers,http-methods localhost Starting Nmap 7.99 (https://nmap.org) at 2026-05-26 12:59 +0500 Nmap scan report for localhost (127.0.0.1) Host is up (0.0010s latency). Other addresses for localhost (not scanned): ::1 PORT STATE SERVICE 3000/tcp open ppp Nmap done: 1 IP address (1 host up) scanned in 1.02 seconds</pre>				

nmap -sV -O localhost

Services	Nmap Output	Ports / Hosts	Topology	Host Details	Scans
	nmap -sV -O localhost				
Host (127.0.0.1)	<pre>Starting Nmap 7.99 (https://nmap.org) at 2026-05-26 12:51 +0500 Nmap scan report for localhost (127.0.0.1) Host is up (0.00033s latency). Other addresses for localhost (not scanned): ::1 Not shown: 996 closed tcp ports (reset) PORT STATE SERVICE VERSION 135/tcp open msrpc Microsoft Windows RPC 445/tcp open microsoft-ds? 2179/tcp open vmrpd? 3000/tcp open ppp? 1 service unrecognized despite returning data. If you know the service/version submit.cgi?new-service : SF-Port3000-TCP:V=7.99%I=7%D=5/26%Time=6A1550F5%P=i686-pc-windows-windows% SF:r(GetRequest,2887,"HTTP/1.1\x20200\x20OK\r\nAccess-Control-Allow-Origi SF:n:\x20*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20S SF:AMEORIGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/ SF:/jobs\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-a SF:ge=0\r\nLast-Modified:\x20Tue,\x202026\x20May\x202026\x2007:35:07\x20GMT\ SF:r\nETag:\x20W/\x20"26d0-19e633572d4"\r\nContent-Type:\x20text/html;\x20ch SF:arset=UTF-8\r\nContent-Length:\x209936\r\nVary:\x20Accept-Encoding\r\nD SF:ate:\x20Tue,\x202026\x20May\x202026\x2007:51:17\x20GMT\r\nConnection:\x20 SF:close\r\n\r\n<!--\r\n\r\n\x20~\x20Copyright\x20(c)\x202014-2026\x20Bj SF:oern\x20Kimminich\x20&\x20the\x20OWASP\x20Juice\x20Shop\x20contributors SF:.\r\n\r\n\x20~\x20SPDX-License-Identifier:\x20MIT\r\n\r\n\x20-->\r\n\r SF:n<!doctype\x20html>\r\n<html\x20lang=\x20"en"\x20data-beasties-container SF:>\r\n<head>\r\n\r\n\x20<meta\x20charset=\x20"utf-8"\x20>\r\n\r\n\x20<title>OW SF:ASP\x20Juice\x20Shop</title>\r\n\r\n\x20<meta\x20name=\x20"description"\x SF:20content=\x20"Probably\x20the\x20most\x20modern\x20and\x20sophisticated\x SF:20insecure\x20web\x20application"\x20>\r\n\r\n\x20<meta\x20name=\x20"viewport SF:20content=\x20"width=device-width,\x20initial-scale=1"\x20>\r\n\r\n\x20<1 SF:ink\x20rel=\x20"preconne")&r(Help,2F,"HTTP/1.1\x20400\x20Bad\x20Request\ SF:r\nConnection:\x20close\r\n\r\n")&r(NCP,2F,"HTTP/1.1\x20400\x20Bad\x20 SF:Request\r\nConnection:\x20close\r\n\r\n")&r(HTTPOptions,EA,"HTTP/1.1\x SF:20204\x20No\x20Content\r\nAccess-Control-Allow-Origin:\x20*\r\nAccess- SF:Control-Allow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Ac SF:cess-Control-Request-Headers\r\nContent-Length:\x200\r\nDate:\x20Tue,\x SF:2026\x20May\x202026\x2007:51:17\x20GMT\r\nConnection:\x20close\r\n\r\n" SF:)&r(RTSPRequest,EA,"HTTP/1.1\x20204\x20No\x20Content\r\nAccess-Control SF:-Allow-Origin:\x20*\r\nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,P SF:ATCH,POST,DELETE\r\nVary:\x20Access-Control-Request-Headers\r\nContent- SF:Length:\x200\r\nDate:\x20Tue,\x202026\x20May\x202026\x2007:51:17\x20GMT\r SF:\r\nConnection:\x20close\r\n\r\n");</pre>				

Mitigations Applied: Rate Limiting + Helmet Security Headers

2. Winston Logging Implementation

Features Implemented:

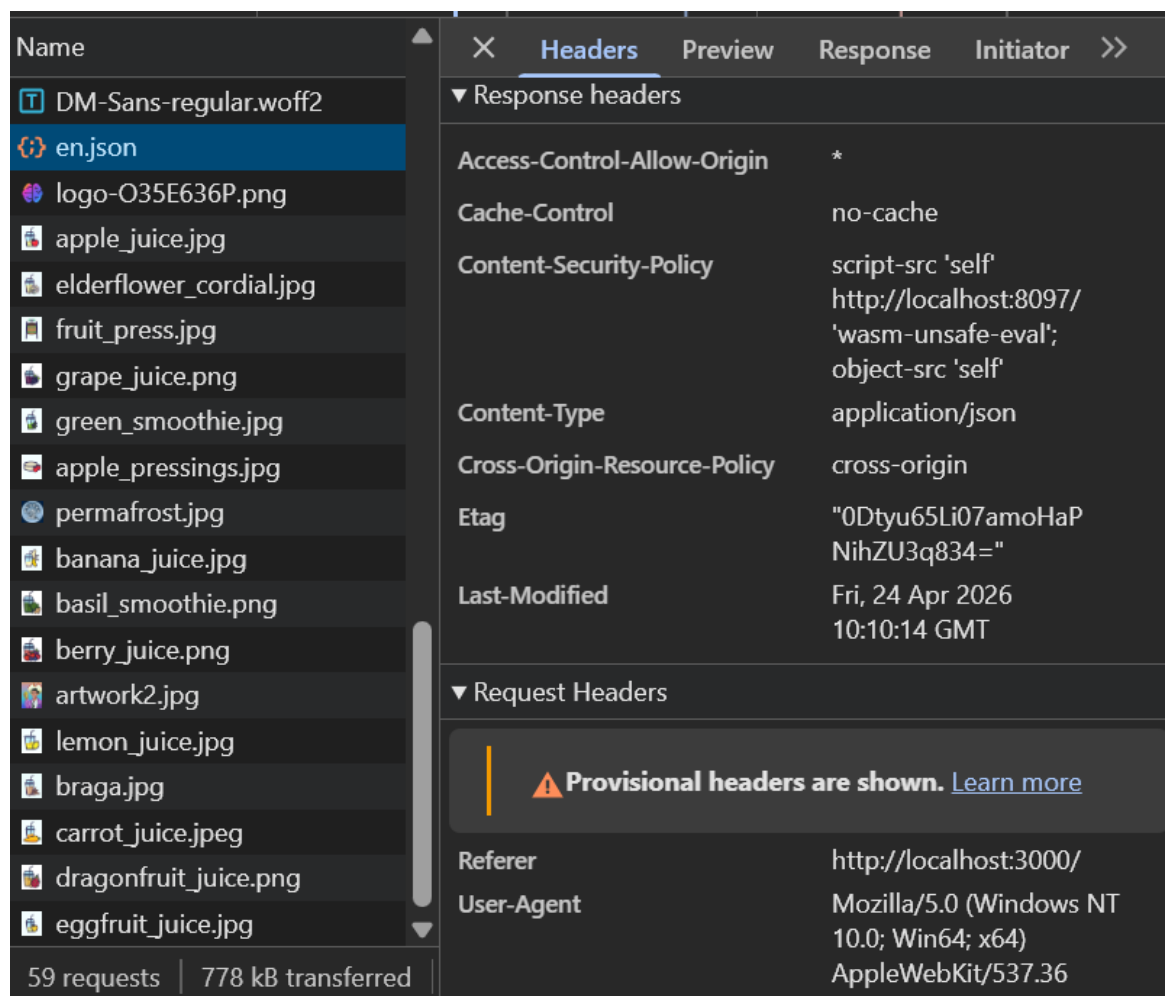
- Structured logging with Winston
- Console + File logging
- Error handling integration

3. Security Enhancements

Implemented:

- Helmet (Security Headers)
- Rate Limiting
- Global Error Handler
- Password Hashing

Screenshots:



```
juice-shop > utils > JS logger.js > stream > write
1  import { createLogger, format, transports } from 'winston';
2
3  const logFormat = format.combine(
4    format.timestamp({ format: 'YYYY-MM-DD HH:mm:ss' }),
5    format.errors({ stack: true }),
6    format.splat(),
7    format.json()
8  );
9
10 const logger = createLogger({
11   level: process.env.NODE_ENV === 'production' ? 'info' : 'debug',
12   format: logFormat,
13   transports: [
14     new transports.Console({
15       format: format.combine(
16         format.colorize(),
17         format.simple()
18       )
19     }),
20     new transports.File({
21       filename: 'logs/error.log',
22       level: 'error'
23     }),
24     new transports.File({
25       filename: 'logs/combined.log'
26     })
27   ],
28   exceptionHandlers: [
29     new transports.File({ filename: 'logs/exceptions.log' })
30   ]
31 });
32
33 // Very simple stream
34 export const stream = /
```

```

app.use(helmet());

const limiter = rateLimit({
  windowMs: 15 * 60 * 1000,
  max: 100,
  message: 'Too many requests from this IP, please try again later.'
});
app.use(limiter);

// Global Error Handler
app.use((err: Error, req: Request, res: Response, next: NextFunction) => {
  logger.error('Unhandled Application Error', {
    message: err.message,
    stack: err.stack,
    path: req.path,
    method: req.method
  });
  res.status(500).json({ message: 'Internal Server Error' });
});

// Start Server
server.listen(PORT, () => {
  logger.info(`🚀 Server started successfully on port ${PORT}`);
});

```

Security Checklist & Best Practices

- All inputs validated
- Passwords hashed with bcrypt
- Security headers enabled
- Rate limiting active
- Proper logging system
- No sensitive data leaked in errors

Challenges & Learnings

- Worked on large TypeScript project
- Learned practical security implementation

Future Improvements

- HTTPS configuration
- Automated security testing